Project 25-26J-043

IAS — Cyber Security | SLIIT Faculty of Computing

CAPSLOCK

CONTAINER-AWARE POLICY SECURITY LOCK

IT22347626 Kulatunga K K M D
IT22338716 Raigambandarage N K
IT22353634 Guruge S A L
IT22345028 Pandukabhaya H D T

PP2 PANEL COMMENTS & ACTIONS TAKEN - PANEL: CS-P03

Component & ID	PP2 Comments Received	Action Taken
MEDS IT22347626	1. Need to have a more feasible licensing model for commercialization. 2. Final presentation should be done in a more prepared manner to utilize the time better for demonstration.	Redesigned commercialization into a 3-tier open-source-first model (Community / Enterprise / Managed Cloud) with explicit pricing and feature boundaries.
EAPE IT22338716	1. Need to have a more feasible licensing model for commercialization. 2. Final presentation should be done in a more prepared manner to utilize the time better for demonstration. 3. Validation is not presented as of now, more fine-tuning needed.	Same commercialization and presentation improvements as above. Expert validation completed with 3 independent industry professionals (Deloitte Cyber, Tudor Capital, NCINGA). Structured feedback collected; system-level assessment table and 4 component-level changes implemented.
ICAP OPERATOR IT22347626	1. Need to have a more feasible licensing model for commercialization. 2. Final presentation should be done in a more prepared manner to utilize the time better for demonstration.	Redesigned commercialization into a 3-tier open-source-first model (Community / Enterprise / Managed Cloud) with explicit pricing and feature boundaries.
SDLB IT22345028	1. Need to have a more feasible licensing model for commercialization. 2. Final presentation should be done in a more prepared manner to utilize the time better for demonstration.	Redesigned commercialization into a 3-tier open-source-first model (Community / Enterprise / Managed Cloud) with explicit pricing and feature boundaries.

CAPSLOCK — OVERALL SOLUTION

PROBLEM IN BRIEF

1. Environment-Blind Policy Enforcement

Kubernetes admission controllers apply fixed policies regardless of dev/staging/prod context, no risk scoring, no environment awareness.

2. ICAP Outside K8s Orchestration

Content scanning (antivirus, DLP) operates independently, no health-aware autoscaling, no K8s-native management, no deployment gating.

DESIGN EXCELLENCE > OVER EXISTING SOLUTIONS

vs. Styra DAS / OPA alone

CAPSLock adds ICAP scanning + environment-aware deployment gating

vs. Falco / Sysdig

Operates at admission layer, not runtime, prevents issues before deployment

vs. Aqua / Prisma Cloud

Narrower but deeper, tight policy + ICAP niche with K8s-native operator pattern

THE FOUR COMPONENTS

MEDS

6-factor deployment risk scoring | Dev → Staging → Prod gating

EAPE

7-factor env. detection | OPA + Kyverno dual-engine translation

ICAP OPERATOR

6-dim. health scoring | K8s-native ClamAV autoscaling

SDLB

Prometheus metrics | Istio VirtualService routing

HOW IT WORKS

IT22347626

Kulatunga K K M D

A Kubernetes Operator that evaluates a 6-factor weighted risk score before permitting any deployment to advance across environment tiers. Each promotion request is scored in real time via a FastAPI REST layer; if the score falls below the tier threshold, the deployment is blocked and the reason is logged with a full audit trail.

MEDS : MULTI-ENVIRONMENT DEPLOYMENT SYSTEM

KEY FUNCTIONALITY

6-Factor Risk Engine

Policy changes, config complexity, ICAP coverage, version delta, compliance posture, env. transition, each weighted and scored live

USLO — Unified Security Lifecycle Orchestrator

Orchestrates Audit → Enforce transitions across 4 frameworks (CIS, PCI-DSS, SOC2, ISO 27001) with grace periods and rollback planning

REST API + Live Dashboard

10+ FastAPI endpoints; web dashboard with policy dropdowns, real-time risk scores, and deployment decision visibility

VALIDATION METRICS

100%
Risk Score Accuracy
30/30 test cases

83
Total Tests
30 risk + 17 e2e + 36 others

45ms
Policy Evaluation
avg. latency (<100ms req.)

24
Compliance Policies
mapped across 4 frameworks

Project 25-26J-043

SLIIT FACULTY OF COMPUTING

2026.05.06

HOW IT WORKS

IT22338716

Raigambandarage N K

A Go binary exposed via Python FastAPI that inspects namespace metadata and computes a 7-factor confidence score to classify the environment (dev/staging/prod). The engine then selects the appropriate compliance policy bundle and translates it simultaneously into OPA Gatekeeper Rego and Kyverno CEL — eliminating dual-engine configuration drift from a single source of truth.

EAPE : ENVIRONMENT -AWARE POLICY ENGINE

KEY FUNCTIONALITY

7-Factor Confidence Scoring

Direct labels, alt. labels, security consistency, compliance req., multi-standards, namespace patterns, risk alignment, produces a weighted confidence score

Dual-Engine Policy Translation

Single EAPE policy → OPA Rego + Kyverno CEL simultaneously; automated compliance rule injection; eliminates drift

4-Strategy Conflict Resolution

Precedence, security-first, environment-aware, manual — with full audit trail; detects 5 conflict types across policy bundles

VALIDATION METRICS

COMPLIANCE COVERAGE:
CIS K8s Benchmark v1.9
PCI-DSS v4.0
SOC2
ISO 27001

96.7%
Classification Accuracy
87/90 namespace configs

95%
Config Effort Reduction via automation

900ms
Policy Selection Time
(< 10s requirement)

164
Total Tests
145 Go + 19 Python

Project 25-26J-043

SLIIT FACULTY OF COMPUTING

2026.05.06

HOW IT WORKS

IT22353634

Guruge S A L

A Kubebuilder-based Kubernetes operator that manages ClamAV/c-icap deployments as CRDs. Every 30 seconds it computes a 6-dimensional health score using Analytic Hierarchy Process (AHP) weights, then reconciles the HPA to scale replicas up or down, replacing CPU/memory-only autoscaling with security-aware health metrics.

ICAP OPERATOR : KUBERNETES-NATIVE CONTENT SCANNING

KEY FUNCTIONALITY

6-Dimensional Health Score

Readiness 25%, Latency 20%, Error Rate 20%, Signature Age 15%, Resources 10%, Queue Depth 10% — computed via Health = $\Sigma(w_i \times m_i)$

CRD-Managed Deployment Lifecycle

Full lifecycle management of ICAP pods as Kubernetes-native CRDs; reconciliation loop via controller.go; autoscaling/v2 HPA

Pluggable Scanner Interface

Modular scanner architecture allows Trivy, Grype, or behavioural tools to supplement ClamAV alongside signature-based scanning

VALIDATION METRICS

STANDARDS :
ICAP RFC 3507
Kubernetes Operator Pattern (CNCF) AHP Weights (Saaty, 1980)

30s
Health Score Interval
6 dimensions per cycle

HPA ✓
Autoscaling
reconcileHPA() implemented

5
Benchmark Scenarios
simulated degradation

100%
Core Implementation
CRD + Operator + Scoring

Project 25-26J-043

SLIIT FACULTY OF COMPUTING

2026.05.06

HOW IT WORKS

IT22345028

Pandukabhaya H D T

A FastAPI controller running a closed observe-decide-enforce loop. It polls Prometheus for ICAP replica health signals, computes optimal traffic weights using a hysteresis state machine (to prevent replica flapping), then pushes updated weights to the Istio VirtualService. Supports configurable fail-open/fail-closed policy when all replicas degrade simultaneously.

SDLB : SERVICE DISCOVERY & LOAD BALANCER

KEY FUNCTIONALITY

Prometheus-Driven Decision Engine

Queries real-time health metrics from Prometheus; computes per-replica weights; updates Istio VirtualService with zero-downtime traffic shifting

Hysteresis State Machine

Prevents replica flapping under transient load spikes; configurable thresholds; supports N-version ICAP replica sets with automatic discovery

Configurable Fail Policy

Fail-open (allow uninspected traffic) or fail-closed (block all traffic) when all replicas degrade, trade-off explicitly documented and operator-configurable

ROUTING FLOW:
Istio Ingress → SDLB Controller → Prometheus → VirtualService Update

Stack:
Python · FastAPI · Prometheus · Istio VirtualService · K3s / Kubernetes

VALIDATION METRICS

~45ms Routing Decision Time 17 test scenarios	**< 5s** Failover Time 2 failover cycles
100% Zero-Downtime Switching Validated	**✓** Manual Override Complete

Project 25-26J-043

SLIIT FACULTY OF COMPUTING

2026.05.06

EXPERT VALIDATION: INDUSTRY PROFESSIONAL REVIEW & CHANGES IMPLEMENTED

E1

Consultant, Cyber Strategy & Transformation

Deloitte Advisory Services
5 yrs | Cybersecurity

E2

DevOps/Automation Engineer

Tudor Capital (The Tudor Group)
7 yrs | FinTech/Cloud Infra

E3

Cybersecurity Engineer

Offensive Security - NCINGA
3+ yrs | Red Team / VAPT

SYSTEM-LEVEL ASSESSMENT

Criteria	E1	E2	E3
Architecture Design	Satisfactory	Excellent	Excellent
Practical Feasibility	Satisfactory	Good	Good
Integration Coherence	Satisfactory	Excellent	Good
Security Value	Satisfactory	Excellent	Good

CHANGES IMPLEMENTED BASED ON FEEDBACK

MEDS

Risk factor weights documented with clear rationale and made operator-tunable via environment variables.

EAPE

Compliance claims reframed to "technical control alignment", scoped to workload-level controls (CIS 4.1–4.5).

ICAP OPERATOR

Pluggable scanner interface added (Trivy/Grype) alongside ClamAV to address signature-based coverage gap.

SDLB

Configurable fail-open/fail-closed policy implemented; hysteresis latency gap documented as near-term roadmap.

COMMERCIALIZATION: OPEN-SOURCE-FIRST BUSINESS MODEL

Community Edition
Apache 2.0 Open Source

Free

✓ Core operator + CRDs for all 4 components
✓ CIS Benchmark v1.9 policy templates
✓ Basic 6-factor risk scoring (MEDS)
✓ Single-cluster ICAP operator
✓ Request-rate Istio routing (SDLB)
✓ Community support via GitHub Issues

Enterprise
per node / month

$10–25

✓ Multi-cluster orchestration + policy sync
✓ Full compliance: PCI-DSS v4.0, SOC2, ISO 27001
✓ USLO — Unified Security Lifecycle Orchestrator
✓ Advanced 4-strategy conflict resolution
✓ KEDA-based ICAP autoscaling
✓ Audit trail export + SIEM integration

Managed Cloud
pricing by cluster size

Custom

✓ Fully hosted CAPSLock control plane
✓ Cross-cluster policy synchronisation
✓ SLA-backed content scanning
✓ Centralised multi-tenant dashboard
✓ Automated compliance reporting
✓ 24/7 support + incident response

Market: \$1.2B (2024) → \$4.8B (2030) · 26% CAGR · 50,000+ enterprise cluster targets

Economics: 4 devs × 6mo ≈ \$150K · 500+ nodes @ \$15/node = \$90K+ ARR in 24 months

Modelled on: Styra (OPA) Sysdig (Falco) Solo.io (Istio)

LIMITATIONS

- SDLB hysteresis may introduce a latency window during sudden large batch deployments
- No multi-tenant / namespace-isolation testing conducted

FUTURE IMPROVEMENTS

- Formal unit test suite for ICAP Operator health scoring module
- Multi-tenant cluster testing with namespace isolation
- RBAC hardening + mutual TLS between all CAPSLock components

THANK YOU

CAPSLOCK — CONTAINER-AWARE POLICY SECURITY LOCK

IT22347626 KULATUNGA K K M D
IT22338716 RAIGAMBANDARAGE N K
IT22353634 GURUGE S A L
IT22345028 PANDUKABHAYA H D T

Project 25-26J-043

IAS — Cyber Security | SLIIT Faculty of Computing